Amadou MANE
Detection and Response Engineer

Threat Intelligence in Wazuh: Detecting — and Investigating — a Known-Malicious IP

Building IOC (CDB) lists in Wazuh and a rule that matches events against them, proving it with a live attack from the lab's attacker box, then running the full SOC investigation playbook on the resulting alert.

Lab goal	Environment	Skills exercised
Detect attackers by known indicator (not just behavior), then investigate the alert end to end like a SOC analyst.	SecMon (.131): Wazuh 4.14.5. NexusShield-corp (.133, agent 001): protected endpoint. DayGone (.135): Kali attacker.	Threat intelligence, CDB lists, Wazuh rules, IOC matching, MITRE mapping, SOC triage & investigation.

1. Behavior vs. indicator

The existing 21 detection rules catch attackers by **what they do** — brute force, scanning, reverse shells. Threat intelligence catches them by **who they are**: a known-bad IP, domain, or file hash. If an indicator is already on a blocklist, there is no need to wait for the behavior to unfold — the SIEM should alert the moment it appears.

> **The pipeline**
> A feed or manual entry populates a CDB list → Wazuh compiles it to a binary .cdb → a rule looks up each event's field (here, the source IP) against the list → a hit raises an alert. Behavioral and intel detection run side by side.

2. Build the IOC lists (CDB)

Three lists live under `etc/lists/malicious-ioc/` — IPs, domains, and file hashes. The attacker box (DayGone, 192.168.112.135) is added to the IP list as the lab's test indicator, alongside live feed entries.

```
# add the attacker IP to the list
sudo tee -a /var/ossec/etc/lists/malicious-ioc/malicious-ip <<'EOF'
192.168.112.135:daygone-lab-attacker
EOF

# register in ossec.conf <ruleset> (if not already present)
<list>etc/lists/malicious-ioc/malicious-ip</list>

# compile: the manager builds the .cdb on restart
sudo systemctl restart wazuh-manager
```

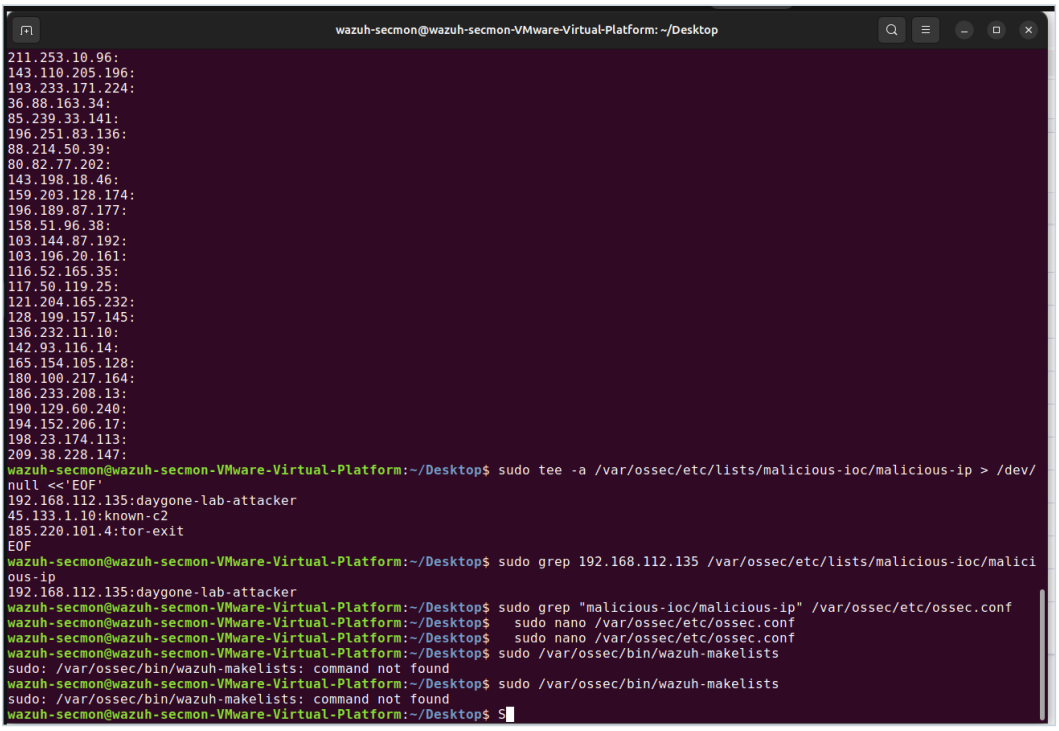


Figure 1. The attacker IP (192.168.112.135) appended to the malicious-ip CDB list, which also holds live threat-feed entries.

3. The IOC matching rule (INC-018)

```
<rule id="100022" level="12">
  <if_group>authentication_failed</if_group>
  <list field="srcip" lookup="address_match_key">etc/lists/malicious-ioc/malicious-ip</list>
  <description>NightFallNode: Login attempt from known-malicious IP (threat-intel / IOC match)</description>
  <mitre><id>T1071</id></mitre>
  <group>threat_intel,ioc_match,attack,</group>
</rule>
```

- **if_group authentication_failed** — runs only on failed-login events, which carry a source IP.
- **list field="srcip" lookup="address_match_key"** — takes the event's source IP and looks it up in the malicious-IP list (address_match_key does IP/CIDR matching).
- A hit raises a **level-12** alert. (match_key is used for exact strings like domains and hashes.)

4. Prove it — live attack from DayGone

From the attacker box, five SSH login attempts against the protected endpoint, NexusShield-corp:

```
for i in 1 2 3 4 5; do
  ssh -o StrictHostKeyChecking=no -o ConnectTimeout=3 baduser@192.168.112.133
done
```

```
┌──(nightfallnode㉿DayGone)-[~]
└─$ for i in 1 2 3 4 5; do ssh -o StrictHostKeyChecking=no -o ConnectTimeout=3 baduser@192.168.112.133; done
baduser@192.168.112.133's password:
Permission denied, please try again.
baduser@192.168.112.133's password:
Permission denied, please try again.
baduser@192.168.112.133's password:
baduser@192.168.112.133: Permission denied (publickey,password).
baduser@192.168.112.133's password:
Permission denied, please try again.
baduser@192.168.112.133's password:
```

Figure 2. Failed SSH logins from DayGone against NexusShield-corp — each writes the attacker IP into the endpoint's auth log.

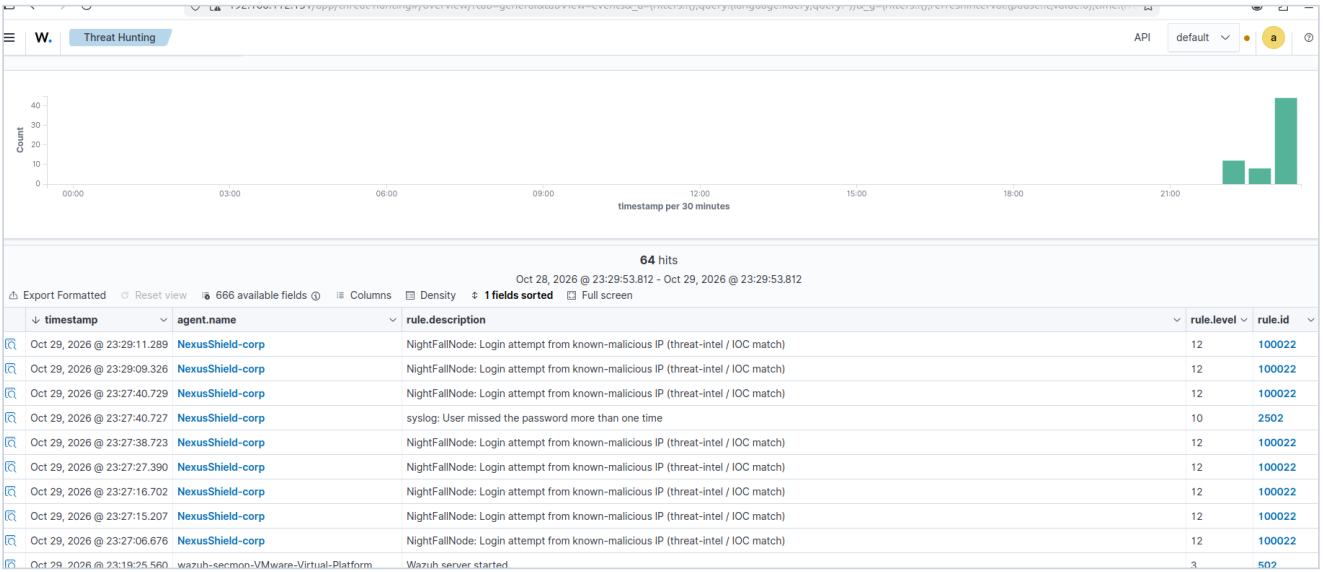
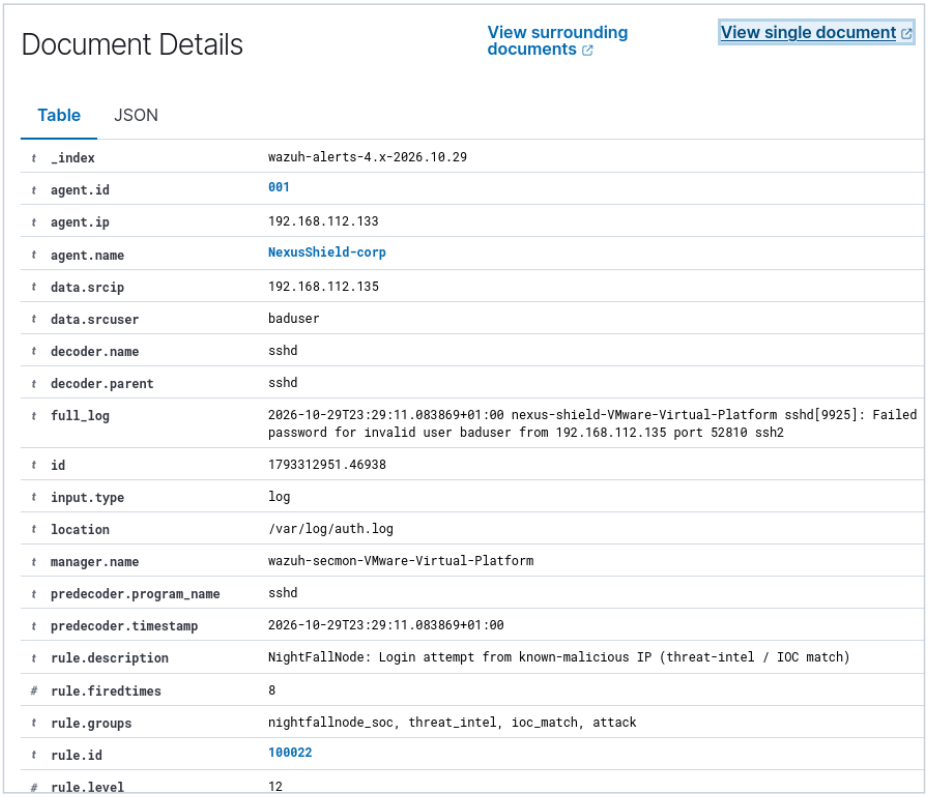


Figure 3. Wazuh Threat Hunting: rule 100022 (level 12) fires on NexusShield-corp for each attempt. Built-in rule 2502 fires alongside it — behavioral and intel detection together.

5. The alert, in detail



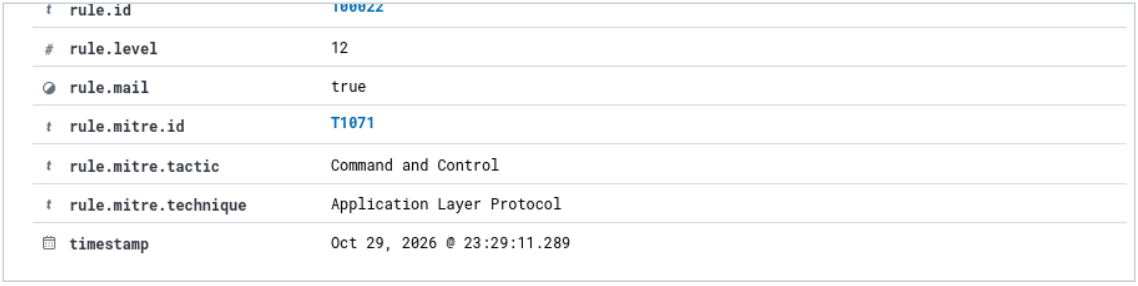
Document Details

View surrounding documents | View single document

Table | JSON

t _index	wazuh-alerts-4.x-2026.10.29
t agent.id	001
t agent.ip	192.168.112.133
t agent.name	NexusShield-corp
t data.srcip	192.168.112.135
t data.srcuser	baduser
t decoder.name	sshd
t decoder.parent	sshd
t full_log	2026-10-29T23:29:11.083869+01:00 nexus-shield-VMware-Virtual-Platform sshd[9925]: Failed password for invalid user baduser from 192.168.112.135 port 52810 ssh2
t id	1793312951.46938
t input.type	log
t location	/var/log/auth.log
t manager.name	wazuh-secmon-VMware-Virtual-Platform
t predecoder.program_name	sshd
t predecoder.timestamp	2026-10-29T23:29:11.083869+01:00
t rule.description	NightFallNode: Login attempt from known-malicious IP (threat-intel / IOC match)
# rule.firedtimes	8
t rule.groups	nightfallnode_soc, threat_intel, ioc_match, attack
t rule.id	100022
# rule.level	12

Figure 4. The alert document: data.srcip 192.168.112.135 is the field matched against the list; full_log carries the raw sshd evidence; agent NexusShield-corp (001).



t rule.id	100022
# rule.level	12
rule.mail	true
t rule.mitre.id	T1071
t rule.mitre.tactic	Command and Control
t rule.mitre.technique	Application Layer Protocol
timestamp	Oct 29, 2026 @ 23:29:11.289

Figure 5. Rule metadata: id 100022, level 12, 8 fired times, MITRE T1071 (Command and Control).

Mapping note: T1071 fits traffic from known-bad infrastructure. For this specific event (a failed SSH login) T1110 (Brute Force) or T1078 (Valid Accounts) are equally defensible — the behavioral rule 100001 carries T1110, so the intel rule keeps T1071.

6. SOC investigation playbook

Detection is only half the job. This is how the alert is triaged and closed — the question that drives everything is **did anything succeed?**

Step	Action	In this case
1. Triage / validate	Why is the IP listed? Confirm it is not your own infra (false positive).	List label daygone-lab-attacker — confirmed hostile, not FP
2. Scope the source	Pivot on `data.srcip`, not the rule. Other endpoints? Time window?	Single agent (NexusShield-corp); short burst of 5 attempts
3. Success vs. fail	The decisive check. Search for authentication_success / "Accepted" from the IP.	**No success** — attempt only, invalid user
4. Scope accounts	Which usernames? Any real/privileged ones? Lockouts?	baduser — invalid account, pure guessing, low risk
5. Endpoint check	On the host: last/lastb, new users, ~/.ssh keys, cron, listeners.	No new users, keys, cron or listeners — no compromise
6. Enrich / contain / document	Reputation (AbuseIPDB/VT/GreyNoise); block the IP; open a DFIR-IRIS case.	Blocked at firewall; case opened in DFIR-IRIS

Key investigation commands (on the endpoint)

```
sudo grep 'Accepted' /var/log/auth.log | grep 192.168.112.135   # did any login SUCCEED?
sudo lastb -n 10                # recent failed logins (the attack)
sudo last -n 10                 # recent successful logins
tail -5 /etc/passwd             # unexpected new users?
sudo ls -la ~/.ssh/ /root/.ssh/  # rogue authorized_keys?
sudo crontab -l; ls -la /etc/cron.*   # persistence?
ss -tnp                         # unexpected connections / listeners
```

Analyst verdict (ticket close-out)
Known-bad IP 192.168.112.135 attempted SSH brute force against NexusShield-corp (agent 001), targeting invalid user *baduser*. 8 failed attempts, **no successful authentication**, single endpoint. Blocked at firewall. No compromise — monitoring continued. (who → what → scope → success/fail → action → verdict)

7. Automate the feed

A static IOC list goes stale fast. A daily cron pulls a live feed (e.g. abuse.ch Feodo Tracker), rebuilds the list while preserving the lab entry, recompiles, and restarts — keeping the SIEM current on its own.

```
# /usr/local/bin/update-iocs.sh (cron: 0 5 * * *)
curl -s https://feodotracker.abuse.ch/downloads/ipblocklist.txt \
  | grep -vE '^#' | grep -E '^[0-9]' | awk '{print $1":feodo-c2"}' \
  >> /var/ossec/etc/lists/malicious-ioc/malicious-ip
sudo systemctl restart wazuh-manager
```

8. Key takeaways

Question	Answer
Behavioral vs. threat-intel detection?	Behavioral catches the unknown (the technique); intel catches the known (the indicator). A real SOC runs both — here 100001 and 100022 fired on one attack.
Why CDB lists?	Fast, exact lookup of atomic indicators (IP/domain/hash) with low false positives — compiled to binary for speed.
What makes the investigation?	The success-vs-fail check. Failed attempts are noise to document; one success is an incident to contain.
Why automate the feed?	IOCs age fast. Without a daily refresh the list is half fiction within weeks.

Watch the full live labs
YouTube: **https://www.youtube.com/@cyberops401unauthorized**
Twitch (live labs): **https://www.twitch.tv/cyberops401unauthorized**